

Acme Corp Third-Party Vendor Risk Assessment Guide

Scope

This guide applies to any third-party vendor that will process, store, or transmit Acme Corp data, or that will be granted access to Acme Corp internal systems.

Risk Tiers

Vendors are assigned to one of three risk tiers. Tier 1 vendors handle sensitive customer data or have privileged system access and require an annual security audit. Tier 2 vendors handle internal but non-sensitive data and require a security questionnaire every two years. Tier 3 vendors have no data access and require no ongoing review.

Required Documentation

Tier 1 and Tier 2 vendors must provide a current SOC 2 Type II report or equivalent, a summary of their data encryption practices, and a named security point of contact before a contract is signed.

Offboarding

When a vendor relationship ends, the vendor access to all Acme Corp systems must be revoked within 24 hours, and the vendor must provide written confirmation that all Acme Corp data has been deleted or returned within 30 days.